

INFORME EXHAUSTIVO: NIST AI RISK MANAGEMENT FRAMEWORK

EXECUTIVE SUMMARY

El **NIST Artificial Intelligence Risk Management Framework (AI RMF)** ha evolucionado desde su lanzamiento en enero 2023[162] hacia un ecosistema integrado de marcos operacionales que abordan IA generativa, seguridad de componentes IA, y defensa resiliente contra ataques basados en IA[72]. Simultáneamente, **España** acelera su marco regulatorio mediante transposición del Reglamento (UE) 2024/1689[35], implementación de la Directiva NIS2[58], y creación de AESIA (Agencia Española de Supervisión de Inteligencia Artificial)[167][168].

Hallazgos Críticos

1. **Funcionalidad NIST Operacionalizada:** Las cuatro funciones core (GOVERN, MAP, MEASURE, MANAGE) se han expandido con subcategorías formalizadas que especifican roles, métricas cuantificables, y cadencias de revisión[161][163]. MEASURE establece siete características de trustworthiness (valid, safe, secure, accountable, explainable, privacy-enhanced, fair)[162][165].
2. **Vulnerabilidades de Cadena Suministro Amplificadas:** 512.847 paquetes malignos detectados (↑156% YoY)[81]; 3,000+ modelos trojanizados en HuggingFace[138]; data poisoning, model extraction, y compromiso CI/CD identificados como vectores prioritarios[139][144][147].
3. **Capacidad Territorial España:** Posición 15º global (NCSI 89.17/100)[56]; 97.348 incidentes en 2024 (↑16.6% vs. 2023)[166]; 31.540 dirigidos a empresas (↑43.2%)[166]; 183.851 sistemas vulnerables identificados[166]. Inversión €1.157M 2025-2026[37].
4. **Métricas Formalizadas con Flexibilidad Contextual:** NIST RMF prescribe marcos de medición pero deliberadamente NO especifica umbrales numéricos, maximizando adaptabilidad[162][165][163].
5. **Integración CSF 2.0:** NIST CSF 2.0 (febrero 2024)[77] e integración explícita de IA[77]; Cyber AI Profile (enero 2026, draft) con tres ejes (Secure, Defend, Thwart)[72][80].

Funcionalidad NIST Operacionalizada: Las cuatro funciones core (GOVERN, MAP, MEASURE, MANAGE) se han expandido con subcategorías formalizadas que especifican roles, métricas

cuantificables, y cadencias de revisión[161][163]. MEASURE establece siete características de trustworthiness (valid, safe, secure, accountable, explainable, privacy-enhanced, fair)[162][165].

Vulnerabilidades de Cadena Suministro Amplificadas: 512.847 paquetes malignos detectados (↑156% YoY)[81]; 3,000+ modelos trojanizados en HuggingFace[138]; data poisoning, model extraction, y compromiso CI/CD identificados como vectores prioritarios[139][144][147].

Capacidad Territorial España: Posición 15ª global (NCSI 89.17/100)[56]; 97.348 incidentes en 2024 (↑16.6% vs. 2023)[166]; 31.540 dirigidos a empresas (↑43.2%)[166]; 183.851 sistemas vulnerables identificados[166]. Inversión €1.157M 2025-2026[37].

Métricas Formalizadas con Flexibilidad Contextual: NIST RMF prescribe marcos de medición pero deliberadamente NO especifica umbrales numéricos, maximizando adaptabilidad[162][165][163].

Integración CSF 2.0: NIST CSF 2.0 (febrero 2024)[77] e integración explícita de IA[77]; Cyber AI Profile (enero 2026, draft) con tres ejes (Secure, Defend, Thwart)[72][80].

I. EVOLUCIÓN NIST AI RMF: TIMELINE Y CICLO FRAMEWORK (2023-2026)

A. Versiones Publicadas y Roadmap Oficial

Versión	Fecha	Característica Clave	Referencias	Estado
AI RMF 1.0	Enero 2023[162]	4 funciones (GOVERN, MAP, MEASURE, MANAGE); 7 características trustworthiness[162][165]	Referencia técnica base para regulaciones futuras	Operativo
NIST CSF 2.0	Febrero 2024[77]	6 funciones (+ IDENTIFY, DETECT, RESPOND, RECOVER); integración AI explícita[77]	Ciberseguridad crítica + resiliencia; guidance para ENS	Operativo
GenAI Profile (AI 600-1)	Abril 2024[88]	400+ acciones mitigación LLM/GenAI[82]; riesgos amplificados documentados[82]	Futuras regulaciones GenAI; orientación SOCs[74]	Operativo
Cyber AI Profile (Draft)	Enero 2026[72][80]	Secure/Defend/Thwart; integración ciberseguridad-IA[72][74][164]	Guidance operativa NIS2 + EU AI Act[80][164]	Draft (comentarios hasta 30 enero 2026)

B. Drivers de Actualización

6. Presión Regulatoria EU AI Act: Operacionalización Art. 28-99 (Q2 2026) requiere alignment NIST → requisitos legales[35][49]
7. GenAI Mainstreaming: Riesgos únicos (hallucinations, jailbreaking, IP theft, token leakage) no previstos en RMF 1.0[82][93]
8. Supply Chain Attacks: NSA + OpenAI (abril 2024) documentan APT usando ChatGPT para malware development[85][86]
9. C-Suite Mandate: 67% large orgs referencia NIST en governance policies[153]

II. FUNCIONES NIST OPERACIONALIZADAS: GOVERN-MAP-MEASURE-MANAGE

A. GOVERN: Infraestructura Organizacional de Riesgo IA

Subcategorías Formalizadas (GOVERN 1-6)[161]

GOVERN 1: Políticas, Procesos, Procedimientos[161]

- Mapeo formal requisitos legales (GDPR, LOPD, EU AI Act Art. 28-99)[161]
- Integración características trustworthiness en ciclo completo[111][161]
- Determinación apetito riesgo mediante escalas RAG o simulaciones[111][161]
- Inventario modelos, políticas decommissioning, whistleblower procedures[111]

GOVERN 2: Accountability Structures[161]

- RACI matrix: Executive Sponsor, AI Risk Committee, Product Owners, Model Stewards[111][161]
- Independencia: Separación desarrollo/testing; prevención conflictos[161]
- Capacitación mandatoria: Leyes, riesgos, políticas trustworthiness[161]
- Escalada de riesgos hasta Board level[161]

GOVERN 3: Diversity, Equity, Inclusion, Accessibility (DEIA)[161]

- Equipos interdisciplinarios (legal, psicología, ingeniería, ciencias sociales)[161]
- Diferenciación roles en configuraciones humano-IA (oversight vs. operación)[161]
- Espacios psicológicamente seguros para cuestionamiento sin represalias[161]

GOVERN 4-6: Cultura riesgo, engagement stakeholders, gestión third-party[161]

B. MAP: Contexto + Impacto + Caracterización Riesgo (5 categorías)[116][161]

MAP 1: Context Established & Understood[161]

- Propósito intencional documentado + beneficial outcomes[161]
- Stakeholder impact mapping (usuarios finales, operadores, comunidades, reguladores)[161]
- Alternativas no-IA evaluadas como potentially more trustworthy[161]
- Implicaciones legales (GDPR, anti-discriminación, data retention)[161]

Métrica de Completitud: (Contexto documentado / Contexto requerido) × 100% → Target ≥95%[116]

MAP 2: Categorization Performed[161]

- Tarea técnica definida sin ambigüedad[161]
- Límites conocimiento documentados (edge cases, OOD escenarios)[161]
- Configuración humano-IA clarificada (% automation vs. human-in-loop)[111]
- Dependencias upstream/downstream identificadas[161]

MAP 3-5: Capacidades, beneficios, riesgos priorizados, caracterización impacto[161]

Red Teaming Participativo: Stakeholders + comunidades impactadas identifican harm escenarios[112]

C. MEASURE: Operacionalización de Trustworthiness (7 categorías)[163][165]

Las Siete Características Trustworthiness[162][165]

Característica	Métrica Primaria	Umbral NIST Sugerido	Referencias
Valid & Reliable	Precision, Recall, F1-score, AUC-ROC	Precision ≥ 0.95 global; disparity $< 5\%$	[162][165][16]
Safe	MTTR (Mean Time To Recover)	MTTR < 15 min, residual risk $< 10\%$	[162][165]
Secure & Resilient	Model extraction detection rate, MTTD anomalías	Detection $> 95\%$; MTTD < 1 h; breach $< 0.1/1000$	[162][165]
Accountable & Transparent	Audit trail completeness (%), GDPR response time	100% audit trail; response < 30 días	[162][165]
Explainable & Interpretable	SHAP/LIME coverage (%), explanation quality score	Coverage $> 90\%$; quality $\geq 4/5$	[162][165]
Privacy-Enhanced	Data minimization ratio, PET implementation %	Minimization $> 70\%$; PET $> 80\%$ systems	[162][165]
Fair (Bias Managed)	Demographic parity gap, equalized odds	Gap $< 5\%$; equalized odds $< 3\%$	[162][165]

MEASURE 1: Methods & Metrics Identified[163][165]

- Seleccionar métricas per trustworthiness characteristic[163]
- Documentar riesgos/características no-medibles con justificación[2]
- Pre-deployment TEVV (Test, Evaluation, Validation, Verification)[22][111]

MEASURE 2: Trustworthy Characteristics Evaluated[163]

- Rigor TEVV escalado por risk tier (Low/Medium/High/Critical)[163]
- Model Cards completados[111][163]
- Accuracy, bias, robustness, privacy, security testing[111][163]
- Independencia: Testing team $\neq$ Development team[111]

MEASURE 3: Emergent Risks Tracked[163]

- Feedback mechanisms (end-user, impacted communities)[163]
- Red teaming continuo (scheduled every 6 months)[163]
- Risk register updates (trimestral mínimo)[163]

MEASURE 4: Measurement Effectiveness Validated[163]

- % métricas validadas por evaluadores no-relacionados: Target $\geq 80\%$ [163]
- Stakeholder feedback incorporation: Target $\geq 50\%$ [163]

D. MANAGE: Orquestación Riesgos + Respuesta Incidentes (4 categorías)[161]

MANAGE 1: Mitigation Actions Prioritized & Resourced[161]

- Risk Mitigation Matrix: avoid/reduce/share/accept per riesgo[161]
- Resource allocation by risk priority[161]
- Timeline: Quick wins (0-30d), medium-term (1-3m), long-term (3-12m)[111]

MANAGE 2: Residual Risk Tolerance[161]

- Post-mitigation risk assessment[161]
- Go/No-Go decision: Residual risk $\leq$ risk tolerance $\rightarrow$ GREEN[161]
- Contingencies: Kill switches, fallbacks, deprecation timelines[161]

MANAGE 3: Incident Response & Communication[161]

- Incident playbooks (>5 types documentados)[161]
- SLA by severity: Critical <15 min assignment, <1h status, <4h resolution plan[161]

MANAGE 4: Monitoring & Continuous Improvement[161]

- KPIs tracked quarterly: deployment success rate ($\geq 95\%$), incident frequency ($< 2/1000$ model-years), validation coverage ($\geq 95\%$)[161]

III. CADENA SUMINISTRO IA: VULNERABILIDADES CRÍTICAS (2024-2026)

A. Landscape de Amenazas Documentadas

1. HuggingFace Trojanized Models (Febrero-Octubre 2024)[138][144]

Hallazgo: 3,000+ malicious model files detected by ProtectAI[138][141]

Técnica: Pickle files (PyTorch) con arbitrary code execution[138][150]

- Credencial theft, AWS API key extraction[138]
- Reverse shells[138]

Caso: Fake 23AndMe Model[138]

- Miles descargas pre-detección[138]
- AWS credential theft $\rightarrow$ infrastructure compromise[138]

Respuesta: ProtectAI scanning integrado en HuggingFace; flag "Unsafe" pre-descarga[138][144]

2. PyPI Supply Chain Attack (Mayo 2024)[137][143]

Paquetes Malignos: aliyun-ai-labs-snippets-sdk, ai-labs-snippets-sdk[137]

- 1,700+ descargas <24 horas[137]
- Infostealer oculto en PyTorch models[137]
- Exfiltración .gitconfig (GitHub tokens)[137]

Escala Ampliada: 100+ malicious packages targeting ML libraries (PyTorch, Matplotlib)[137][143][149]

- Typo-squatting (PyToich vs. PyTorch)[137][143][149]
- Cryptominers, info stealers, reverse shells[137]

3. Ultralytics YOLO11 Compromise (Diciembre 2024)[81][146]

Impacto: XMRig cryptominer injected en object detection library[81]

- Transitive dependency impact[146]
- Resource consumption escalada[146]

Lección: Model integrity checking prerequisite pre-CI/CD[81]

B. Vectores de Ataque Mapeados (NIST Cyber AI Profile)[72][80][139]

Vector	Técnica	NIST Función	Métrica Detección
Data Poisoning	Contaminación training data[139]	MAP 1, MEASURE 2	% data validated ≥99%[139]
Model Extraction	Queries → replicación modelo[139]	GOVERN 1, MEASURE 1	Query pattern analysis[139]
Prompt Injection	Manipulación LLM bypass guardrails[139][86]	MAP 1, MEASURE 2	Prompt pattern anomalies[139]
CI/CD Compromise	Inyección pipelines[80]	GOVERN 1, MANAGE 1	Commit verification[80]
Dependency Confusion	Trojanized librerías populares[142]	GOVERN 1, MEASURE 1	Version mismatch alerts[142]

C. Solución Emergente: ML-BOM (Machine Learning Bill of Materials)[142][151]

Componentes a Catalogar[142]:

- Pre-trained models (source, version, hash, provenance)
- Training data (source, license, PII risk)
- Dependencias (framework versions, CVE tracking)
- Data processing pipelines (vendor, security posture)
- Deployment infrastructure (cloud provider, compliance)
- Third-party services (APIs, data flows, DLP status)[142]

Beneficios[142]:

- Detectar paquetes malignos pre-deploy[142]
- Compliance EU AI Act (Art. 28-29 trazabilidad)[142]
- Alignment NIST MAP 1 + MEASURE 1[142]

IV. CONTEXTO TERRITORIAL ESPAÑA: NORMATIVA + CAPACIDAD INSTITUCIONAL

A. Normativa Vigente (2024-2026)

1. Reglamento (UE) 2024/1689 (Ley de IA)[35][167][171]

Timeline Operacionalización[171]:

- 2 febrero 2026: Capítulos I-II operativos[171]
- Agosto 2026: Art. 50 (transparencia usuarios) obligatorio[171]
- Q2 2026: Art. 28-99 (conformidad, sanciones) operativos[171]

Sanciones[171]:

- Muy graves: €35M o 7% volumen negocio[171]
- Graves: €15M o 4% volumen[171]
- Leves: €10M o 2% volumen[171]

Autoridad: AESIA (Agencia Española Supervisión IA)[167]

- Creada marzo 2025[167][171]
- Director General: Ignasi Belda Reig[167]
- Estructura: Presidencia (Secretaría Estado Digitalización e IA), Dirección, Consejo Rector (8 miembros)[167]
- Cuerpo de inspección operativo a partir 2 agosto 2025[167]

Enfoque Risk-Based[171]:

- Prohibited (art. 5): Sistemas causing clear, unacceptable harm
- High-Risk (art. 6-28): Assessment systems, employment, law enforcement
- Limited-Risk (transparency): Chatbots, deepfakes
- Minimal-Risk: Open source, low-impact[171]

2. Directiva NIS2 + Transposición España (RD 443/2024 + ENS)[58][66][69]

Vigencia España: 17 octubre 2024 (transposición legislativa oficial)[58]

12 Sectores Críticos Bajo Supervisión INCIBE[58]:

Energía, Transporte, Agua, Salud, Telecomunicaciones, Admin. Pública, Defensa, Finanzas, Infraestructuras digitales, Espacial, Química-Industrial, Alimentación[58]

Obligaciones Críticas[58]:

- Evaluación riesgos periódica (anual mínimo)[58]
- Implementación medidas gestión riesgos[58]

- Notificación incidentes <72 horas[58]
- Auditorías independientes (trienales)[58]

Sanciones: €10-20M o 2-4% volumen anual[58]

3. Estrategia Nacional IA (2024) + Plan Nacional Ciberseguridad (2025-2026)[37][40]

Coordinador: SEDIA (Secretaría Estado Digitalización e IA)[37]

Inversión: €1.157M (ciberseguridad + resiliencia digital)[37]

Iniciativas Clave[37]:

- Integración IA en SOC's nacionales[37]
- Red Competencia Nacional (NCC-ES)[37]
- Sandbox regulatorio high-risk AI[37]

B. Indicadores Ciberseguridad Nacional (2024)

Métrica	Valor	Tendencia	Referencia
NCSI Posición Global	15º (89.17/100)[56]	Estable vs 2023[56]	[56][169]
Incidentes Totales 2024	97.348[166]	↑ 16.6% YoY[166]	[166][59]
Incidentes en Empresas	31.540 (32%)[166]	↑ 43.2% YoY[166]	[166][59]
Sistemas Vulnerables	183.851[166]	Crítica (OT)[166]	[166][59]
Phishing Cases	21.751[173]	22% del total[173]	[173]
Malware Cases	42.136[166]	Incluyendo 357 ransomware[166]	[166]

Análisis[59][173]: 260 incidentes/día (11/hora); 54% consultas preventivas al 017[166]

C. Capacidad Institucional: INCIBE

Funciones[30][166]:

- Respuesta incidentes (INCIBE-CERT): 97.348 gestionados 2024[166]
- Supervisión NIS2 operadores críticos[166]
- Investigación (Red RENIC)[56]
- Capacitación (INCIBE Emprende, Hacker Academy)[30]

Fortalezas[56][166][167]:

- ✓ Marco legal alineado EU[167]
- ✓ Institución consolidada (20 años)[30]
- ✓ AESIA creada con independencia orgánica[167]
- ✓ Programa capacitación operativo[30][166]

Brechas[56][166]:

- ⚠️ Capacidad SMEs limitada (>80% requieren asistencia)[62]
- ⚠️ Velocidad implementación desalineada calendarios políticos[171]
- ⚠️ Métricas IA aún en desarrollo (no hay estándares españoles vs NIST aún)

V. RESILIENCIA DIGITAL + CONTINUIDAD NEGOCIO CON IA

A. Datos Cuantitativos: Integración IA en Disaster Recovery[97][106]

Hallazgo IDC (2024): Organizaciones con automatización IA-driven reportan **€2.44M de ahorro promedio[97]** en costos brechas; MTTR reducido 60-75%[97][109]

Métricas de Resiliencia[100][103]:

- RTO (Recovery Time Objective): < 4 horas sector energía[97]
- RPO (Recovery Point Objective): < 15 minutos[97]
- Disponibilidad sistémica: ≥ 99.9% (máximo 8.76h downtime/año)[97]
- MTTR (Mean Time To Detect): < 15 minutos anomalías[97]

B. Casos de Uso Sector Crítico España

Sector Energía: Red Eléctrica Ibérica, ENDESA, Iberdrola[124][130]

Riesgo: SCADA compromise → blackout nacional (precedente: abril 2025, 4h outage, €300-500M impacto económico)[130][133]

Implementación NIST[124][133]:

- GOVERN: Políticas fail-safe, deshabilitación automática[133]
- MAP: Stakeholder impact modeling, criticality assessment[124]
- MEASURE: Anomaly detection OT networks (behavioral analytics)[124][127]
- MANAGE: Recovery orchestration automática[133]

Amenazas IA-Específicas[124][127]:

- Model drift en load forecasting[127]
- Adversarial attacks en grid sensors[127]
- Supply chain compromise en ICS software[127]

Sector Salud: Hospitales Madrid/Barcelona[125][128]

Riesgo: Ransomware diagnosis systems → unavailable workflows[125][128]

Implementación NIST[125]:

- MAP: Impact assessment (patient harm timeline)[125]
- MEASURE: Stress testing bajo condiciones reales[125]
- MANAGE: Incident playbook, patient communication < 15 min[125]

Criticidad: Segregación red imaging/laboratorio (air-gapped de EMR); daily backup verification; quarterly DR drills[125][128]

Sector Transporte: Renfe, Aeropuertos, Puertos[136]

Riesgo: IA navegación/scheduling comprometida → disruption masiva[136]

Implementación NIST[136]:

- Secure: Model integrity verification pre-deployment[136]
- Defend: IA defensiva detección patrones ataque[136]
- Thwart: Redundancia + human override < 2 min[136]

VI. RECOMENDACIONES ESTRATÉGICAS ESPAÑA 2026-2028

Para Autoridades Regulatorias (AESIA, INCIBE, SEDIA)

1. Publicar Guía Mapeo NIST → EU AI Act (Target: Q2 2026)[49][52]

- Checklist conformidad dual (GOVERN 1-3 ↔ EU AI Act Art. 28-99)[49][52]
- Ejemplos sector-específicos (sanitario, energía, transporte)[49]
- FAQs ambigüedades regulatorias[49]

2. Extender ENS con AI-Specific Controls (Target: Q4 2026)

- Integrar MEASURE function de NIST[77][4]
- Requerir documentación trustworthiness (audit trail 100%, Model Card)[4]
- Audit protocol de evaluación independiente

3. Desarrollar Métricas por Sector (Target: Q1 2027)

- Energía: SCADA anomaly detection benchmarks[127]
- Salud: Diagnosis accuracy/fairness thresholds[125][128]
- Transporte: Safety metrics autonomous systems[136]
- Finanzas: Credit scoring fairness, fraud detection robustness[123][129]
- Publicar anualmente (similar CIS Benchmarks)[135]

Para Sector Privado (Operadores Críticos & SMEs)

Track 1: Operadores Esenciales (Pre-implementación antes 2027)

1. Formar AI Governance Committee (Board-level oversight)[155][156]
2. Documentar inventario sistemas IA (risk tier)[155][156]
3. Establecer risk tolerance statements[155][156]
4. Implementar GOVERN + MAP → baseline compliance Q2 2026[155][156]

Track 2: Programa Acelerado SMEs (Cohort 1: Q3 2026)[155][156]

1. INCIBE financing: €50-100K grants per SME[155]
2. Peer mentoring: Large orgs → SME partners (6-month engagement)[155]
3. Certificación madurez IA: Roadmap ISO/IEC 42001 (2027-2028)[155][156]

Track 3: Supply Chain Security (Iniciativa inmediata Q1 2026)[142][147]

1. Auditar modelos pre-entrenados (provenance, integrity)[142][147]
2. Implementar ML-BOM para todas dependencias third-party[142]
3. Participar threat intelligence sharing (INCIBE-CERT)[147][166]

Para Academia & I+D

1. Centros Excelencia NIST (Target: Q3 2026)[56][152][154]

- UAM, UPM, UC3M: Labs de evaluación NIST RMF[152]
- Investigación métricas fairness/robustness contextualizadas[152]
- Publicaciones (NDSS, USENIX Security, AAAI/FAccT)[152]

2. Proyectos CDTI Alineados (Target: Convocatoria Q2 2026)

- "Detección Data Poisoning en Cadena Suministro IA"[89][142]
- "Auditoría Model Extraction: Defensas y Detección"[95]
- "Resiliencia IA Infraestructura Crítica"[97][106]
- Presupuesto: €2-5M por proyecto[152]

3. Colaboración Internacional (Año completo)

- Participación AIRC (NIST AI Resource Center)[108]
- Benchmarking vs. Alemania (BSI), Francia (ANSSI), Holanda (NCSC)[44]
- Standardization (ISO/IEC working groups)[151]

VII. ROADMAP IMPLEMENTACIÓN ESPAÑA 18-24 MESES

Fase 1: Cimientos (Meses 1-6)

Mes 1-2: Gap Analysis + Governance Setup[111][155]

- INCIBE/AESIA: Publicar guía mapeo NIST → EU AI Act[155]
- Constituir AI Risk Committees (operadores críticos)[155][161]
- Formar centros evaluación (UAM, UPM, UC3M)[152]

Mes 3-4: MAP + Inventory Creation[111][116]

- AI Use Case Inventory (high-risk + critical infrastructure)[116]
- Stakeholder mapping[116]
- Data governance baseline[111]

Mes 5-6: MEASURE Baseline[111][163]

- Seleccionar métricas iniciales[163]
- Pre-deployment testing protocols (TEVV)[111][163]
- Capacitación técnica[111]

Fase 2: Operacionalización (Meses 7-12)

Mes 7-8: Pilot Deployments (3-5 sistemas críticos)[96][155]

- Hospital (diagnostics)[125]

- Banco (credit scoring)[123][129]
- Utility (SCADA anomaly)[127]
- Model Cards, incident playbooks[96][155]

Mes 9-10: Supply Chain Hardening[142][147]

- ML-BOM para third-party models[142]
- Auditoría HuggingFace/PyPI (malicious packages)[138][143][144]
- Vendor security requirements[142][147]

Mes 11-12: Portfolio Governance[155][161]

- Risk dashboard operativo (KPIs)[155][161]
- Board reporting template[155][161]
- Q4 risk assessment portfolio[155]

Fase 3: Escala + Continuidad (Meses 13-24)

Mes 13-18: Expansion SMEs[155][156]

- INCIBE financing €50-100K per SME[155]
- Peer mentoring[155]
- Certificación madurez: ISO/IEC 42001 roadmap[156]

Mes 19-24: EU AI Act Full Compliance[171]

- AESIA audits (Art. 28-99 operativo Q2 2026)[171]
- Todos sistemas high-risk documentados + auditable[155][171]
- Harmonization Francia (ANSSI), Alemania (BSI)[44]

VIII. CONCLUSIONES Y OUTLOOK 2026-2028

Síntesis Estratégica

España está **bien posicionada para adoptar NIST AI RMF como herramienta técnica de implementación** del EU AI Act[49][52]. Convergencia de:

10. Madurez normativa: AESIA operativa[167], INCIBE consolidada[166], ENS actualizable[4][77]
11. Inversión creciente: €1.157M 2025-2026[37] (suficiente para iniciar, insuficiente para escala masiva)
12. Capacidad institucional: Red RENIC[56], centros excelencia (UAM, UPM), programas capacitación[30]

Riesgos Residuales No Mitigados

13. Velocity Gap: Amenazas IA evolucionan más rápido que regulación (6+ meses típicamente)[81][85][86]
14. SME Capacity Gap: 80% SMEs requieren asistencia técnica intensiva (costo: €100K+ per org)[62]
15. Supply Chain Opacity: Paquetes malignos PyPI/HuggingFace aún no diferenciables confiablemente pre-deploy[137][138][143]

Timeline Crítico: Hitos Inmediatos 2026

Fecha	Responsable	Entregable	Impacto
Feb 2026	AESIA	Entrada vigencia EU AI Act operativa[171]	Conformidad legal inmediata
Abril 2026	INCIBE/SEDIA	Guía NIST → EU AI Act[155]	Reduce ambigüedad (3-6m aceleración)
Junio 2026	Sector Privado	Auto-auditoría systems high-risk[155]	Visibility pre-AESIA enforcement
Agosto 2026	Todo Sector	Art. 50 (transparencia usuarios)[171]	Millones sistemas afectados
Q4 2026	NIST	Cyber AI Profile final[72][80]	Guidance post-operacionalización

REFERENCIAS BIBLIOGRÁFICAS

- [2] AuditBoard (2025-01-13). "The Core Functions of the NIST AI RMF." <https://auditboard.com/blog/nist-ai-rmf>
- [4] Nemko Digital (2023-05-31). "NIST AI Risk Management Framework (AI RMF 1.0)." <https://digital.nemko.com/regulations/nist-rmf>
- [9] CyberSaint (2025-09-10). "How To Align with the NIST AI RMF: Step-by-Step Playbook." <https://www.cybersaint.io/blog/nist-ai-rmf>
- [13] The AI Alliance (2023-12-31). "NIST Artificial Intelligence Risk Management Framework." <https://the-ai-alliance.github.io/trust-safety-user-guide>
- [16] Scrut.io (2025-04-15). "NIST AI Risk Management: Key Insights & Challenges." <https://www.scrut.io/post/nist-ai-risk-management-framework>
- [22] RSI Security (2025-12-01). "Roadmap to Achieving NIST AI RMF." <https://blog.rsisecurity.com>
- [30] INCIBE (2024-12-31). "What we do." <https://www.incibe.es/en/incibe/corporate-information/what-we-do>
- [35] Artificial Intelligence Act (2025-11-04). "Ley de Inteligencia Artificial de la UE." <https://artificialintelligenceact.eu/es/>
- [37] España (2025-09). "THE ARTIFICIAL INTELLIGENCE STRATEGY 2024." <https://datos.gob.es>
- [40] INCIBE (2026-01). "Digital Spain 2026 Strategy." <https://www.incibe.es>
- [44] Regulance (2025-12-15). "NIST vs EU AI Act: Which AI Risk Management Framework?"

<https://regulance.io>

[49] Regulance (2025-12-15). "NIST vs EU AI Act frameworks comparison." <https://regulance.io>

[52] SoftwareSeni (2025-11-25). "EU AI Act NIST AI RMF and ISO 42001 Compared."

<https://www.softwareseni.com>

[56] NCSI (2025-09-14). "Spain - National Cyber Security Index." <https://ncsi.ega.ee/country/es/>

[58] Flexxible (2025-05-13). "NIS2 Directive Spain: Cybersecurity Requirements 2025."

<https://www.flexxible.com>

[59] ZIUR (2025-06-02). "Spain recorded more than 97000 cybersecurity incidents in 2024."

<https://www.ziur.eus>

[62] Springboard35 (2025-04-14). "Cybersecurity in Spain: Challenges and Opportunities."

<https://springboard35.com>

[66] Vila (2025-02-23). "NEW REGULATION ON CYBERSECURITY. THE NIS2 DIRECTIVE AND ITS STATE OF APPLICATION IN SPAIN." <https://vila.es>

[69] ENISA (2019). "National Cybersecurity Strategy 2019 - Spain." <https://www.enisa.europa.eu>

[72] SiliconAngle (2025-12-17). "NIST releases draft AI cybersecurity framework profile."

<https://siliconangle.com>

[74] Stinson (2026-01-07). "New Guidance from NIST Demonstrates How Organizations Can Use AI for Cybersecurity." <https://www.stinson.com>

[77] NIST (2024-02). "The NIST Cybersecurity Framework (CSF) 2.0."

<https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>

[80] Global Policy Watch (2026-01-05). "NIST Publishes Preliminary Draft of Cybersecurity Framework Profile for Artificial Intelligence." <https://www.globalpolicywatch.com>

[81] ExtraHop (2026-01-01). "2025 Security Predictions: Attacks on the AI Supply Chain."

<https://www.extrahop.com>

[82] RSI Security (2025-11-17). "Generative Artificial Intelligence Risks & NIST AI RMF Guide."

<https://blog.rsisecurity.com>

[85] Crowell (2026-01-12). "NIST Releases Draft Framework for AI Cybersecurity."

<https://www.crowell.com>

[86] Cloud Security Alliance (2025-11-30). "AI Security Threats: Prompt Injection & Model Poisoning." <https://cloudsecurityalliance.org>

[88] LEXIA (2024-06-05). "NIST's AI Profile: A Global AI Governance Benchmark."

<https://www.lexia.it>

[89] ArXiv (2025-03). "Detecting and Preventing Data Poisoning Attacks on AI Systems."

<https://arxiv.org/pdf>

[93] OWASP (2024-04-10). "LLM Risks Archive - OWASP Gen AI Security Project."

<https://genai.owasp.org/llm-top-10/>

[95] Office1 (2025-06-09). "AI Model Poisoning: What It Is, How It Works, and How to Prevent It."

<https://www.office1.com>

[96] NetSolutions (2025-11-16). "How to Implement NIST AI RMF for Enterprises: A Practical Guide." <https://www.netsolutions.com>

[97] DRJ (2025-12-02). "How AI Is Redefining Both Business Risk and Resilience Strategy."

<https://drj.com>

[100] ISACA (2025-10-30). "Operational Resilience in the Age of Artificial Intelligence."

<https://www.isaca.org>

[103] Fusionrm (2025-04-07). "2025 Trends in Continuity and Resilience."

<https://www.fusionrm.com>

[106] Cristie (2024-09). "The State of Disaster Recovery and Cyber-Recovery, 2024-2025."

<https://www.cristie.com>

[108] NIST (2025-05-04). "AI Risk Management Framework." <https://www.nist.gov>

[111] Dawgen Global (2023-12-31). "NIST AI RMF in Plain English: Govern, Map, Measure, Manage Done Right." <https://www.dawgen.global>

[112] EPIC (2023-04-05). "Framing the Risk Management Framework: Actionable Instructions by NIST in the MAP section." <https://epic.org>

[116] Scrut.io (2024-10-31). "NIST AI RMF Map Function Overview." <https://www.scrut.io>

[123] IMF (2024-07-31). "Spain: Financial Sector Assessment Program-Technical Note."

<https://www.elibrary.imf.org>

[124] GreenPowerMonitor (2025-07-30). "Building Resilient SCADA monitor systems."

<https://www.greenpowermonitor.com>

[125] LinkedIn (2026-01-11). "Spain AI in Hospital Management Market Outlook 2026."

<https://www.linkedin.com>

[127] UC3M e-Archivo (2025). "A Review of Smart Grid Anomaly Detection Approaches." <https://e-archivo.uc3m.es>

[128] EIT Health (2024-06-06). "The adoption of AI solutions in hospitals requires building trust."

<https://eithealth.eu>

[129] OECD (2024-09). "Regulatory approaches to artificial intelligence in finance."

<https://www.oecd.org>

[130] Nozomi Networks (2025). "Major Power Outage Hits Spain and Portugal."

<https://www.nozominetworks.com>

[133] CERRE (2025-12). "Cyber Resilience as a Pillar of European Energy Security."

<https://cerre.eu>

[135] Management Solutions (2024). "Regulation Outlook Report 4Q24."

<https://www.managementsolutions.com>

[136] LinkedIn (2024). "Spain Supervisory Control And Data Acquisition Systems Market."

<https://www.linkedin.com>

[137] SecurityBoulevard (2024-02). "Malicious Packages in npm, PyPI Highlight Supply Chain."

<https://securityboulevard.com>

[138] CSO Online (2025-02-06). "Attackers hide malicious code in Hugging Face AI model pickle files." <https://www.csoonline.com>

[139] OWASP GenAI (2025-05-04). "LLM03:2025 Supply Chain." <https://genai.owasp.org>

[141] Forbes (2024-10-22). "Hackers Have Uploaded Thousands Of Malicious Models To AI's Biggest Online Repository." <https://www.forbes.com>

[142] SecurityBoulevard (2025-04). "Secure Your AI Supply Chain with the ML-BOM."

<https://securityboulevard.com>

[143] TheHackerNews (2025-06). "Malicious PyPI, npm, and Ruby Packages Exposed."

<https://thehackernews.com>

[144] ReversingLabs (2025-02-05). "Malicious ML models discovered on Hugging Face platform."

<https://www.reversinglabs.com>

[147] NSFfocus (2024-03-04). "AI Supply Chain Security: Hugging Face Malicious ML Models."

<https://nsffocusglobal.com>

[149] Mend.io (2025-11-02). "Over 100 Malicious Pkgs Target Popular ML Pypi Libraries."

<https://www.mend.io>

[151] OpenSSF (2025-10-21). "Global Alignment on SBOM Standards: EU Cyber Resilience Act."

<https://openssf.org>

[152] ArXiv (2024-01-15). "Evolving AI Risk Management: A Maturity Model based on NIST AI RMF." <https://arxiv.org/pdf>

[153] Samta.ai (2026-01-12). "Why AI Governance Matters More Than Accuracy."

<https://samta.ai/blogs>

[154] IEEE USA (2024-10-17). "A Flexible Maturity Model for AI Governance Based on NIST AI RMF." <https://ieeeusa.org>

[155] CyberDynamo (2024-03). "NIST AI RMF Implementation Engagement."

<https://cyberdynamo.com>

[156] DIMES Society (2025-10-07). "Health AI Maturity Model." <https://dimesociety.org>

[161] IS Partners (2025-01-29). "Core Functions: Govern, Map, Measure, Manage."

<https://www.ispartnersllc.com>

[162] AIGL Blog (2025-11-17). "NIST AI 100-1: Artificial Intelligence Risk Management Framework." <https://www.aigl.blog>

[163] NIST (2025-02-05). "NIST AI RMF Playbook." <https://www.nist.gov/itl/ai-risk-management-framework>

[164] Keyfactor (2026-01-08). "What the NIST Cyber AI Profile Draft Tells Us About the Future of AI and Cybersecurity." <https://www.keyfactor.com>

[165] Vanta (2025-06-26). "An extensive guide to the NIST AI RMF." <https://www.vanta.com>

[166] INCIBE (2025-03-19). "INCIBE presenta su balance de ciberseguridad 2024 con más de 97.000 incidentes." <https://www.incibe.es>

[167] ProteccionData (2025-03-14). "Agencia Española de Supervisión de la Inteligencia Artificial (AESIA)." <https://protecciondata.es>

[168] AESIA (2025-12-25). "la AESIA - Official Website." <https://aesia.digital.gob.es>

[169] Spain Administration Electrónica (2024-08-31). "Spain's international ranking in Global Cybersecurity Index." <https://administracionelectronica.gob.es>

[171] ProtectionReport (2025-02-05). "Implementación de la Agencia Española de Supervisión de la Inteligencia Artificial." <https://www.protectionreport.com>

[173] MailCommsGroup (2025-04-28). "Phishing, a major cybersecurity challenge." <https://mailcommsgroup.com>

[174] AESIA (2024-12-31). "Guías - AESIA." <https://aesia.digital.gob.es/es/guias>

[176] BBVA (2025-09-14). "AI on both sides of cybersecurity: ally and threat in the digital world."
<https://www.bbva.com>

[177] AESIA (2025). "Guía introductoria al Reglamento de IA."
<https://aesia.digital.gob.es/storage/media>

Informe Completo: Enero 2026

Próxima Revisión: Octubre 2026 (post-AESIA audits + EU AI Act full operability)